

Аналитический отчёт · Безопасность · 9 мая 2026

Telegram Forward ID Spoofing

Разбор инцидента в прямом эфире: верификация источника
и анализ эксплойта подделки системных уведомлений.



Ксайнов

Независимый исследователь • первичная фактура и расследование

Telegram • Forward Spoofing • JSON Exploit • Service Notifications | OSINT

Контекст

9 мая 2026 года в сервисных чатах Telegram — тех самых, куда приходят коды подтверждения входа — появилось сообщение о смерти Павла Дурова, новости о принудительной интеграции с сервисом “госуслуги” и прямые угрозы расправой. Канал был максимально доверенный для любого пользователя. Расследование шло в два последовательных этапа.

Этап первый

Верификация аккаунта

Инструменты: telelog, funstat, ручной анализ метаданных

Первым делом нужно было ответить на вопрос: этот аккаунт вообще официальный? Проверка шла по нескольким независимым критериям.

Номер телефона +33 3... — французский мобильный. Системный чат Telegram привязан к номеру 42777

Список групп через telelog / funstat — аккаунт состоит в десятках обычных чатов: «шарашкина контора», «кормушка», крипто-болталки. Системная сущность Telegram по своему техническому бэкграунду не должна вступать в подобные группы.

Раздел с подарками (18 gifts) — у настоящего системного чата нет раздела с подарками. Сама возможность их дарить отсутствует.

Несовпадение идентификаторов — у официального аккаунта который предназначен для системных уведомлений уникальный и неизменный идентификатор: 777000. Аккаунт для псевдо-системных уведомлений в свою очередь имеет UID: 333000.

Вывод этапа 1: аккаунт **НЕ ОФИЦИАЛЬНЫЙ** — аккаунт не имеет отношения к системе Telegram.

Разбор схемы: как это работало и стоило ли верить

Технический анализ + оценка угрозы.

Верификация показала: аккаунт — не официальный. Но тогда встал следующий вопрос: как именно неофициальный аккаунт попал в доверенную ветку системных уведомлений?

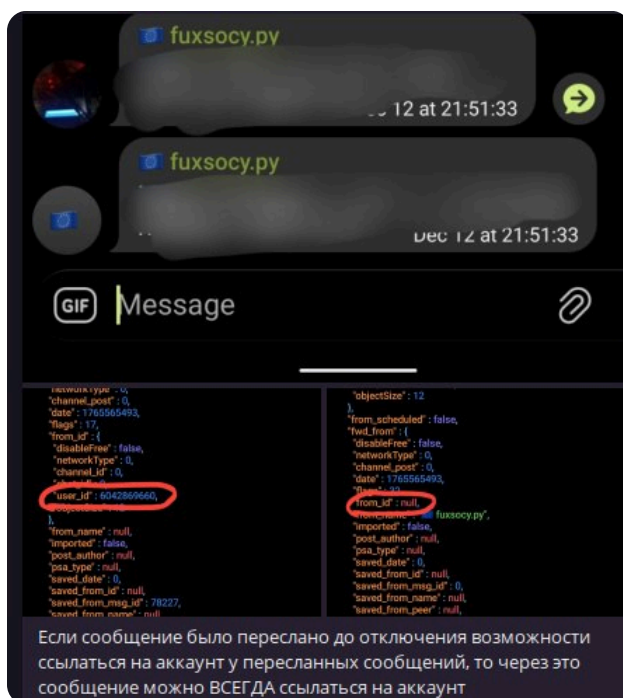
И почему вообще кто-то мог поверить?

Ответ дал **sudosudo**, подтвердил **Петрокат**:

“Telegram определяет, показывать ли ссылку на аккаунт в пересланном сообщении, на основании одного параметра.

Уязвимость: ссылка на аккаунт в forwarded message зависит от того, прописан ли `user_id` в JSON самого сообщения — а не от того, включена ли возможность ссылки у пользователя прямо сейчас.

Вывод: подставив ID псевдо-системного аккаунта (333000), сообщение отображалось как официальное уведомление. Настройки приватности жертвы роли не играли.”



Это означает, что **любой аккаунт** мог сформировать сообщение, которое клиент

воспринимал как системное — с именем «Telegram», попаданием в доверенную ветку и визуальными признаками официальности. Уязвимость, по всей видимости, существовала годами.

Стоило ли верить сообщениям? Нет — по совокупности факторов:

Содержание сообщения («заранее утверждённый протокол», «совет директоров») — **типичный шаблон социальной инженерии для создания паники.**

Официальный канал @durov — молчит.

Итоговое подтверждение от независимых специалистов: «Это эксплойт, который позволял подделать сообщение от кого угодно — пофиксили уже сегодня.»

Вывод этапа 1: **Эксплойт** — верить не стоило, но угроза была реальной.

Оценка угрозы

Нереализованный потенциал — критическая уязвимость

Эксплойт позволял подделать сообщение от любого аккаунта в Telegram. В данном случае его использовали для троллинга и вброса о смерти Дурова. Но та же механика позволяла провести масштабную фишинговую атаку — достаточно попросить «подтвердить аккаунт» от имени системного чата. Или обрушить курс TON. Единственное, что спасло: исполнители оказались непрофессиональными хулиганами.

Благодарности. Спасибо всем, кто стихийно оказался рядом в этом расследовании:

Петропату — за подтверждение факта эксплойта и информацию о фиксе; **sudosudo** — за точную техническую формулировку механики уязвимости; участникам чатов, чьи реакции помогли выстроить таймлайн. Никакой организованной команды не было — просто люди в нужном месте и в нужное время.

